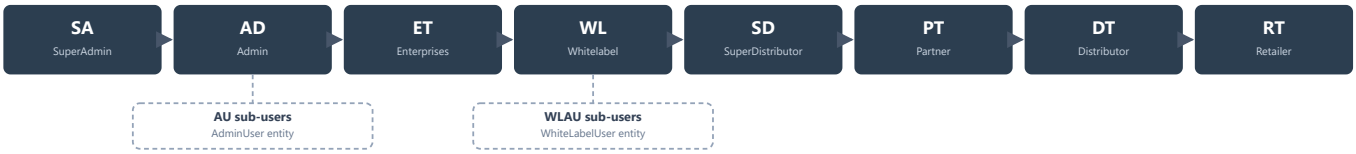
# Hierarchy & Access Model — Structure & Access Flow

InstantMudra Enterprises Admin Portal

### 8-level reseller hierarchy — seeded by HierarchyMasterDataInitializer (Module 1)




### Two independent representations — kept in sync only by application code, no FK between them

**parentAccount (string field)**

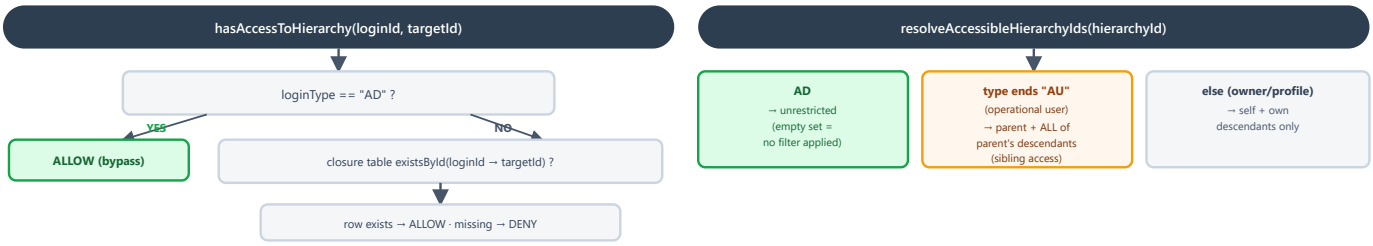
- Hand-copied onto 6 of 7 profile entities: Enterprises, WhiteLabels, SuperDistributor, Partner, Distributor, Retailer
- Also present on AdminUser / WhiteLabelUser (AU/WLAU)
- Admin & SuperAdmin have NO parentAccount (top of chain)
- Plain VARCHAR — no foreign key, no shared base class
- 7 profile entities, no common interface between them

**AccessHierarchyNode + AccessHierarchyPath**

- AccessHierarchyNode: hierarchy_id, hierarchy_type, parent_hierarchy_id
- AccessHierarchyPath: real closure table — {ancestor_id, descendant_id, depth}
- Built by HierarchyAccessService.registerHierarchyNode() → buildClosurePath()
- Gives O(1) ancestor/descendant lookups

⚠ No foreign key ties these together — every hierarchy create must remember to write BOTH the parentAccount column AND call registerHierarchyNode(), or the two views of the tree silently diverge

### Access resolution — HierarchyAccessService / HierarchyAccessValidator




**HierarchyAccessValidator.findParentHierarchy(id)**

⚠ Fragile: type = id.split("-")[1] (breaks on malformed IDs) → repository lookup per type → reflectively calls getParentAccount() — silently returns null on any failure, e.g. for Admin/SuperAdmin which have no such method

### ⚠ CRITICAL — unauthenticated endpoints leak OTPs and wallet balances

TreeDiagramController — /api/hierarchies/*

**GET /view — PUBLIC (matches SecurityConfig + AESFilter whitelist exactly)**

Calls HierarchyAccessService.getHierarchyTree() → renders the full org tree as HTML, including every node's UserDetails (mobile number + live OTP) and prepaid/postpaid wallet balances across all 7 levels. No login required.

templates/hierarchy.html renders whatever the service returns — no per-node auth check applied.

**GET /data?hierarchyId=…&mobileNumber=… — PUBLIC (matches whitelist exactly)**

Calls HierarchyDataService.getCompleteHierarchyData() → JSON dump of userInformation (from the OTP-bearing UserDetails row), walletInformation, assignments, and the full subtree — lookup-able by raw mobile number, no login required.

**GET /tree-diagram — PUBLIC too (corrected — see Module 4)**

AESFilter matches its whitelist via plain String.startsWith(), not exact-path matching — "/api/hierarchies/tree" DOES match "/api/hierarchies/tree-diagram" too. Same OTP + wallet data as /view, exposed as JSON, unauthenticated. All three /view, /data, and /tree-diagram endpoints are confirmed public.

**Net effect: any unauthenticated caller can retrieve any hierarchy's login OTP and wallet balance, by hierarchy ID or by raw mobile number, via any of the three endpoints above.**

Standard structure · Flagged risk / fragile design · Critical — confirmed unauthenticated data exposure · Allow / unrestricted outcome